

Nmap Enumeration Lab (v1) — Ricognizione di rete domestica

Tool utilizzato:

Nmap Target: rete locale domestica (192.168.1.0/24)

Ambiente: Kali Linux (VM UTM, Apple Silicon)

Obiettivo:

Simulare la fase di reconnaissance/enumeration di una valutazione di sicurezza: identificare i dispositivi attivi su una rete e mappare la loro superficie d'attacco (porte aperte, servizi esposti, versioni), lavorando esclusivamente sulla propria rete domestica (unico ambito legale/etico senza autorizzazione esplicita di terzi).

Metodologia:

Il lab segue un approccio a imbuto: prima si individua chi è online (discovery), poi cosa espone (port/service scan), infine si raccolgono dettagli aggiuntivi solo sugli host di interesse (banner grabbing, script NSE) — evitando scansioni aggressive non necessarie.

1. Determinazione del range di rete

`ip a`

Identificato l'indirizzo locale 192.168.1.21/24 , con broadcast 192.168.1.255 . Dalla notazione /24 si deriva il range di rete: 192.168.1.0 – 192.168.1.255.

2. Host discovery

`sudo nmap -sn 192.168.1.0/24`

-sn esegue una scansione di solo discovery (nessun controllo porte), utile per un primo censimento rapido e poco invasivo. Identificati diversi dispositivi (smartphone, tablet, la stessa macchina Kali). Tra questi, il target più rilevante dal punto di vista didattico: un dispositivo con hostname Tenda.station (192.168.1.3, MAC vendor

Tenda Technology) — i dispositivi mobili sono stati scartati perché tipicamente non espongono servizi di rete visibili.

3. Port scan con version detection

```
sudo nmap -sV 192.168.1.3
```

Risultato: 999 porte chiuse, 1 sola porta aperta (80/tcp, HTTP), servizio identificato come GoAhead WebServer — un web server leggero tipico di pannelli di amministrazione su dispositivi embedded/IoT (router, extender). Nessuna versione specifica rilevata dal probing automatico.

4. Banner grabbing manuale

```
curl -I http://192.168.1.3
```

Header HTTP analizzati: Server: GoAhead-Webs (senza numero di versione — buona pratica di hardening lato dispositivo), redirect 302 verso /index.html (pagina di login), header Cache-Control / Pragma: no-cache coerenti con una pagina di autenticazione.

5. Script NSE di default

```
sudo nmap -sV -sC 192.168.1.3
```

Risultati aggiuntivi:

http-title: Extender → rivela il tipo esatto di dispositivo: un WiFi extender/ripetitore, non il router/gateway principale della rete (che è verosimilmente il modem Vodafone, non scansionato in questo lab)

http-trane-info: Problem with XML parsing of /evox/about → falso allarme
identificato correttamente: uno script NSE pensato per rilevare controller Trane (altro tipo di dispositivo IoT) che semplicemente non si applica a questo target — nessuna informazione utile, ma buon esercizio nel distinguere segnale da rumore negli output NSE

Conclusioni

Il dispositivo analizzato (WiFi extender Tenda) presenta una superficie d'attacco minima: una sola porta esposta (interfaccia di amministrazione web), nessuna versione di servizio rivelata negli header, comportamento standard per un pannello di login. Dal punto di vista difensivo è una postura corretta.

Cosa ho imparato

Flusso standard di enumerazione: discovery → port/service scan → banner grabbing
→ script NSE

Interpretazione di header HTTP (Server , Cache-Control , redirect) come fonte di informazione passiva

Distinguere risultati NSE realmente informativi da falsi positivi/rumore di script non pertinenti al target

Riconoscere dai risultati (http-title) il ruolo reale di un dispositivo in rete (extender vs router)

Note e limiti

Lab condotto su rete domestica reale con superficie d'attacco naturalmente ridotta (un solo host con una porta esposta) — utile per la metodologia, ma con risultati limitati in termini di "scoperte". Prossimo step pianificato: ripetere lo stesso flusso su Metasploitable2 (VM deliberatamente vulnerabile), per un esercizio con più servizi/porte da analizzare e un confronto più ricco tra ambienti "reali" (hardened) e ambienti volutamente esposti.